



MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

Puntuación de Métricas MSS con el Metamarco PRAGMATIC

Versión 1.0 — Abril 2026

"Seleccionar métricas sin un criterio explícito es como comprar acciones al azar. PRAGMATIC es la hoja de análisis fundamental que separa los números útiles del ruido."

1. INTRODUCCIÓN A LA MATRIZ

Esta matriz operacionaliza el enfoque **PRAGMATIC Security Metrics** para las métricas MSS definidas en el marco GQM del informe "MSS". Cada métrica candidata se puntúa de 0 a 10 en los nueve criterios PRAGMATIC:

- P — Predictive (Predictivo)
- R — Relevant (Relevante)
- A — Actionable (Accionable)
- G — Genuine (Genuino)
- M — Meaningful (Significativo)
- A — Accurate (Preciso)
- T — Timely (Oportuno)
- I — Independent (Independiente)
- C — Cheap (Rentable/Barato)

La puntuación total (0-90) y la puntuación media (0-10) permiten comparar métricas entre sí y seleccionar aquellas con mejor perfil global[cite:130][cite:131][cite:136][cite:142].

Regla práctica sugerida:

- Adoptar preferentemente métricas con Puntuación total ≥ 60 y sin suspenso (≤ 4) en los criterios P, R y A.

2. LEYENDA DE INTERPRETACIÓN

Rango (0-10)	Interpretación
0-2	Muy pobre: la métrica falla claramente en este criterio
3-4	Débil: valor limitado, riesgo de distorsión
5-6	Aceptable: usable con cautelas
7-8	Buena: aporta valor sólido para este criterio
9-10	Excelente: cumple ejemplarmente el criterio

3. MATRIZ PRAGMATIC PARA MÉTRICAS CORE MSS

3.1. Métricas de Detección y Respuesta

3.1.1. MTTD — Mean Time to Detect

Criterio	Puntuación (0-10)	Justificación resumida
P — Predictive	9	MTTD bajo predice menor probabilidad de daño catastrófico; útil para anticipar necesidades de refuerzo.
R — Relevant	10	Directamente alineado con NIS2 (plazo 24h) y con el impacto económico de incidentes.
A — Actionable	9	Reducciones medibles conducen a decisiones claras (más turnos 24x7, tuning SIEM, IA, MSS ampliado).
G — Genuine	8	Si se captura desde marcas de tiempo de herramientas, los datos son objetivos y reproducibles.
M — Meaningful	9	Comprensible por negocio: "¿en cuánto tiempo nos enteramos de que nos atacan?".
A — Accurate	8	Precisión al minuto posible; requiere definición clara de T0 (inicio del incidente).
T — Timely	8	Disponible casi en tiempo real en SIEM/MDR bien configurado.
I — Independent	7	Moderadamente independiente; cierta tentación de excluir incidentes "incómodos".
C — Cheap	8	Coste bajo: se apoya en datos ya generados por las plataformas.

Total: 76/90 — **Media:** 8,4 — **Veredicto:** Métrica **excelente** para cuadros de mando MSS.

3.1.2. MTTC — Mean Time to Contain

Criterio	Puntuación	Justificación
P	9	Predice la extensión potencial del daño ("blast radius").
R	9	Crítico para evitar propagación de ransomware y movimientos laterales.
A	9	Reducir MTTC implica acciones concretas (automatización, playbooks SOAR, mayor autoridad de SOC).
G	8	Basado en logs de cambios de estado de contención.
M	8	Entendible: "tiempo hasta cerrar la puerta".
A	7	Menor precisión cuando la contención se declara manualmente.
T	8	Derivable de tiempo real de tickets y herramientas.
I	7	Puede sesgarse si se declara contención antes de ser realmente efectiva.
C	8	Similar coste a MTTD, requiere modelado de eventos de contención.

Total: 73/90 — **Media:** 8,1 — **Veredicto:** Métrica **muy recomendable**.

3.1.3. MTTR — Mean Time to Respond/Recover

Criterio	Puntuación	Justificación
P	8	Predice duración de interrupciones; útil para expectativas de negocio.
R	10	Directamente vinculado a RTO/RPO y al coste de interrupciones.
A	9	Permite priorizar inversiones en procesos, automatización y recursos.
G	7	Depende de la definición de "recuperación completa"; riesgo de subjetividad.
M	9	Métrica intuitiva para negocio.
A	7	Precisión media en entornos complejos con restauraciones progresivas.
T	7	Cálculo típico post-mortem; no siempre disponible en tiempo real.
I	7	Riesgo de declarar cierre de incidente por presión política.
C	8	Coste bajo; requiere buena disciplina en cierre de tickets.

Total: 72/90 — **Media:** 8,0 — **Veredicto:** Métrica **crítica**, con cuidado en definiciones.

3.1.4. FPR — False Positive Rate

Criterio	Puntuación	Justificación
P	7	No predice directamente incidentes, pero sí fatiga de analistas y riesgo de omisión.
R	8	Alta relevancia operativa en SOC.
A	8	Accionable vía tuning, whitelisting, mejora de reglas e IA.
G	7	Requiere etiquetado cuidadoso de casos; riesgo de clasificación inconsistente.
M	7	Comprensible, pero puede malinterpretarse sin contexto.
A	7	Precisión condicionada por calidad del etiquetado.
T	8	Actualizable casi en tiempo real en sistemas con workflow maduro.
I	7	Puede manipularse etiquetando menos falsos positivos.
C	8	Bajo coste incremental; se basa en datos del SOC.

Total: 66/90 — **Media:** 7,3 — **Veredicto:** Métrica **muy útil**, requiere gobernanza del etiquetado.

3.2. Métricas de Cobertura y Vulnerabilidades

3.2.1. ACR — Asset Coverage Ratio

Criterio	Puntuación	Justificación
P	8	A mayor ACR, menor probabilidad de activos invisibles comprometidos.
R	9	Directamente vinculado a la máxima "no se protege lo que no se ve".
A	9	Guía acciones claras: inventariar, desplegar agentes, integrar fuentes.
G	7	Depende de la completitud del inventario; riesgo de infrarregistro.
M	8	Intuitivo: porcentaje de superficie de ataque "iluminada".
A	7	Precisión media en entornos muy dinámicos (cloud, contenedores).
T	7	Puede ser semanal/mensual; difícil diario sin automatización.
I	8	Bastante independiente si el inventario es automatizado.
C	7	Requiere inversión inicial en CMDB/auto-discovery, coste marginal bajo después.

Total: 70/90 — **Media:** 7,8 — **Veredicto:** Métrica **esencial** para madurez.

3.2.2. Tiempo medio de remediación de CVEs críticas

Criterio	Puntuación	Justificación
P	9	Predice exposición futura a explotación de vulnerabilidades conocidas.
R	9	Directamente vinculada a NIS2 (gestión de vulnerabilidades) y a muchos incidentes reales.
A	9	Accionable: priorizar parches, cambiar ventanas de mantenimiento.
G	8	Basado en fechas de detección/cierre de tickets; genuino si se registra bien.
M	8	Fácil de explicar como "días hasta parchear".
A	7	Precisión razonable; problemas si se agrupan vulnerabilidades.
T	7	Horizonte típico semanal/mensual; suficiente para decisiones.
I	7	Puede "maquillarse" retrasando la fecha de apertura formal de tickets.
C	8	Coste bajo; se apoya en herramientas de VM.

Total: 72/90 — **Media:** 8,0 — **Veredicto:** Métrica **muy recomendable**.

3.3. Métricas de Cumplimiento y Gobernanza

3.3.1. Compliance Score ENS/NIS2/DORA

Criterio	Puntuación	Justificación
P	7	Predice probabilidad de sanciones y hallazgos en auditoría.
R	10	Directamente relevante para cumplimiento y reputación.
A	8	Permite orientar proyectos de adecuación normativa.
G	7	Depende de la calidad de las autoevaluaciones; idealmente auditado externamente.
M	8	Intuitivo: "% de controles cumplidos".
A	7	Precisión condicionada por criterios de auditor.
T	6	Normalmente anual o bienal; poco oportuno para decisiones tácticas.
I	7	Riesgo de sesgos si la autoevaluación recae en equipos evaluados.
C	7	Coste alto si se incluye auditoría externa, pero inevitable regulatoriamente.

Total: 67/90 — **Media:** 7,4 — **Veredicto:** Métrica **imprescindible**, aunque lenta y con sesgos posibles.

3.3.2. % de cuentas con MFA obligatorio

Criterio	Puntuación	Justificación
P	8	Predice reducción de compromisos de credenciales.
R	9	Directamente ligado a NIS2 Art. 21.2 j) y a DORA.
A	9	Accionable: desplegar MFA donde falta.
G	8	Basado en configuraciones de IdP; genuino si se consulta directamente.
M	8	Fácil de explicar: "qué porcentaje usa MFA".
A	8	Alta precisión si el IdP ofrece reporte fiable.
T	8	Puede actualizarse casi en tiempo real.
I	8	Difícil de manipular sin cambiar configuración real.
C	8	Coste bajo: la mayoría de IdP exportan estos datos.

Total: 74/90 — **Media:** 8,2 — **Veredicto:** Métrica de alta prioridad.

3.4. Métricas Financiero-Actuariales

3.4.1. ALE — Annualized Loss Expectancy (sin y con controles)

Criterio	Puntuación	Justificación
P	8	Predice pérdidas esperadas, aunque con incertidumbre.
R	10	Central para decisiones de inversión.
A	9	Permite comparar escenarios de control.
G	6	Depende de supuestos de ARO y EF; requiere transparencia.
M	9	Métrica en euros, significativa para negocio.
A	6	La precisión se ve limitada por la escasez de datos históricos fiables.
T	6	Normalmente anual; útil para presupuestos, no para operación diaria.
I	6	Vulnerable a sesgos inconscientes en la parametrización.
C	7	Coste moderado; requiere trabajo analítico inicial.

Total: 67/90 — **Media:** 7,4 — **Veredicto:** Métrica **estratégica**, con necesidad de gobernanza de supuestos.

3.4.2. ROSI — Return on Security Investment

(Desarrollado en el marco GQM; se incluye aquí resumen)

Criterio	Puntuación	Justificación
P	8	Proyecta el valor económico futuro de las inversiones en seguridad.
R	10	Directamente relevante para CFO/Consejo.
A	9	Permite comparar inversiones alternativas.
G	6	Dependiente de ALE y supuesto de eficacia de controles.
M	9	Habla en términos de "€ ahorrados por € invertido".
A	6	Precisión limitada por la incertidumbre del riesgo.
T	7	Se actualiza en ciclos presupuestarios.
I	6	Riesgo de "optimismo" en parámetros.
C	8	Bajo coste incremental una vez modelado ALE.

Total: 69/90 — **Media:** 7,7 — **Veredicto:** Métrica clave para gobierno económico del riesgo.

3.5. Métricas de Tecnologías Emergentes

3.5.1. Crypto-Agility Score (PQC)

Criterio	Puntuación	Justificación
P	9	Predice capacidad de adaptación a amenazas cuánticas.
R	8	Relevante en sectores con datos de larga vida (banca, salud, defensa).
A	8	Accionable: identificar y priorizar sistemas no ágiles.
G	7	Depende de inventario y análisis arquitectural honesto.
M	7	Concepto nuevo; requiere pedagogía para Alta Dirección.
A	7	Precisión condicionada por calidad del análisis de sistemas.
T	5	Ventana de revisión típicamente anual o multianual.
I	7	Razonablemente independiente si participa arquitectura y seguridad.
C	6	Requiere esfuerzo inicial considerable; coste marginal menor después.

Total: 64/90 — **Media:** 7,1 — **Veredicto:** Métrica **emergente** y estratégica a medio plazo.

4. TABLA RESUMEN DE PUNTUACIONES PRAGMATIC

Métrica	P	R	A	G	M	A (Accurate)	T	I	C	Total /90	Media/10	Prioridad sugerida
MTTD	9	10	9	8	9	8	8	7	8	76	8,4	★★★★★ Muy Alta
MTTC	9	9	9	8	8	7	8	7	8	73	8,1	★★★★★ Muy Alta
MTTR	8	10	9	7	9	7	7	7	8	72	8,0	★★★★★ Muy Alta
FPR	7	8	8	7	7	7	8	7	8	66	7,3	★★★★ Alta
ACR	8	9	9	7	8	7	7	8	7	70	7,8	★★★★★ Muy Alta
T. remediación CVEs críticas	9	9	9	8	8	7	7	7	8	72	8,0	★★★★★ Muy Alta

Compliance Score ENS/NIS2	7	10	8	7	8	7	6	7	7	67	7,4	★★★★ Alta
% cuentas con MFA	8	9	9	8	8	8	8	8	8	74	8,2	★★★★ Muy Alta
ALE	8	10	9	6	9	6	6	6	7	67	7,4	★★★★ Alta
ROSI	8	10	9	6	9	6	7	6	8	69	7,7	★★★★ Muy Alta
Crypto-Agility Score	9	8	8	7	7	7	5	7	6	64	7,1	★★★★ Alta

5. USO DE LA MATRIZ EN LA SELECCIÓN Y REVISIÓN DE MÉTRICAS MSS

1. Selección inicial:
2. Priorizar la inclusión en SLAs y cuadros de mando de métricas con media $\geq 7,5$ y sin suspenso en P, R, A.
3. Revisión anual:
4. Recalificar métricas a la luz de cambios tecnológicos, regulatorios y organizativos.
5. Comparación de métricas candidatas nuevas:
6. Aplicar la matriz PRAGMATIC antes de introducir nuevas métricas en el sistema.
7. Transparencia y gobernanza:
8. Documentar las razones de la puntuación y revisarlas por un comité mixto (CISO, Riesgos, Negocio).

Nota: La matriz aquí presentada ofrece una valoración inicial orientativa basada en literatura especializada y experiencia práctica[cite:130][cite:131][cite:136][cite:139]. Cada organización debería recalibrar las puntuaciones en función de su contexto concreto y apetito de riesgo.

Matriz de Evaluación PRAGMATIC — Versión 1.0 · Abril 2026

Basada en: Brotby & Hinson — PRAGMATIC Security Metrics[cite:130][cite:131][cite:136][cite:142], Smart Approach to Selecting Good Cyber Security Metrics (2024)[cite:139].